Análise de arquivo benigno ou malware

Share

exec.ko

KO

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando a política sobre análise de código malicioso

Vou começar lendo a skill de leitura de arquivos e depois fazer a análise estática do módulo.

Ran 5 commands, read a file

- Ler a skill file-reading antes de tocar no arquivo enviado SKILL.md
- Ran a command
- Identifying the binary as a relocatable kernel module.
- Ran a command
- Settling the verdict and the safe next steps
- Ran a command
- Checking the binary's section sizes.
- Ran a command
- Avaliando se o carregamento se limita ao kernel de origem
- Ran a command
- Organizando as orientações finais para o usuário

Terminei de coletar as evidências estáticas (nada foi executado) e vou consolidar o veredito.

**Veredito: o arquivo não é benigno. É um keylogger em nível de kernel (spyware) e eu o classifico como malware.**

Passo a passo:

1. **Identificação.** `exec.ko` é um módulo de kernel Linux (ELF 64-bit relocável, x86-64) de 622.760 bytes. O nome genérico "exec.ko" não tem relação com o nome interno do módulo (`maK_it`), o que é um sinal fraco de camuflagem.
2. **Metadados.** O autor declarado é "Ciaran McNally - maK", a licença é GPL e o módulo foi compilado com GCC 14.2.0 para o kernel `7.1.13+parrot7-amd64` (Parrot OS). Esses campos são autodeclarados e podem ser falsos.
3. **Tamanho do código.** O `.text` tem só cerca de 950 bytes, e há um `.bss` de cerca de 1 MB (um buffer `keyBuffer` de 1.000.000 bytes). Isso é compatível com um programa que só acumula dados e deixa pouco espaço para outras funções.
4. **APIs do kernel usadas.** Ele importa `register_keyboard_notifier`, que recebe todo evento de teclado do sistema, `__register_chrdev`, que cria um dispositivo de caractere, e `_copy_to_user`, que entrega dados a um processo comum. Não há importações de rede, de arquivos, de execução de processos nem de manipulação de syscalls.
5. **Strings.** Há tabelas de tradução de scancode para caractere, com variações de Shift e marcadores como `[ESC]`, `[BS]`, `[TAB]`, `[ENTR]`, `[CTRL]` e `[SHFT]`, que é o formato típico de um log de teclas. Também aparece a mensagem `maKit: Major %i`.
6. **Indicadores de rede e persistência.** Não encontrei URL, IP, caminho de shell, cron ou systemd. Os resultados com "socket/connect" vêm só dos metadados de tipos (BTF) embutidos no módulo, não do código dele.
7. **Procedência.** O caminho de compilação gravado no debug info é `/home/user/Documents/malwares_rep/RatKeylogger`. Quem compilou o módulo o chamou de "RatKeylogger" dentro de uma pasta de "malwares".

**Por que malware:** a única função do módulo é capturar de forma global e silenciosa tudo o que é digitado (senhas incluídas), guardar em um buffer e expor por um dispositivo para outro processo ler. Isso não tem uso legítimo comum em um sistema, e o próprio caminho de compilação o rotula como malware.

### Ressalvas

- É uma amostra simples. Não tem exfiltração por rede, persistência nem propagação, precisa de root para ser carregada e de outro componente para ler ou enviar os dados. É uma peça de espionagem, não um malware completo e autônomo.
- A intenção não dá para provar só pelo arquivo. Se você o obteve num laboratório de estudo (a pasta "malwares_rep" sugere isso), é uma amostra de pesquisa. Se apareceu em um sistema que não é de laboratório, trate como indicador de comprometimento.
- Foi uma triagem estática para classificar o arquivo. Não detalho o funcionamento interno dele nem ajudo a usá-lo ou modificá-lo.

### O que fazer

- Não carregue o módulo (`insmod`) fora de uma VM descartável e isolada.
- Se o encontrou em uma máquina real, isole-a e troque as senhas digitadas nela a partir de um dispositivo limpo.
- Nessa máquina, verifique `lsmod` e `/proc/modules`, procure a mensagem `maKit: Major` no `dmesg` e considere reinstalar o sistema.

- Secure Boot com assinatura de módulos impede o carregamento de módulos não assinados.

SHA-256 completo, para consultar em bases como o VirusTotal:
`a288c0cec5ba3def8065c2980c19fc0776c7e918bf99239e34a98fb6cc915e6c`

Qual é a categoria principal deste malware?

Avaliando se o componente faz parte de um RAT ▸

A categoria principal é **keylogger**, uma subcategoria de **spyware**. Mais especificamente, é um keylogger em modo kernel, implementado como módulo carregável (LKM) do Linux. Na taxonomia MITRE ATT&CK ele corresponde à técnica T1056.001, Input Capture: Keylogging.

O que o enquadra nessa categoria é que o código só intercepta as teclas digitadas e as disponibiliza para leitura. Não há componentes típicos de outras famílias: não cria acesso remoto, não propaga e não persiste por conta própria. Também não é um rootkit completo, porque não vi, pelas importações, manipulação de syscalls nem ocultação de processos ou arquivos.

O diretório de compilação se chama “RatKeylogger”, o que sugere que a peça foi pensada como componente de um RAT (Remote Access Trojan). Este arquivo, porém, contém apenas a parte de captura de teclas.

